



NIST CSF GAP ASSESSMENT

Assessing a Fictional Company based on
the Functions and Tiers of The NIST CSF 2.0



COMPANY OVERVIEW

Company Name: Nexora Solutions

Industry: Software engineering / custom application development for B2B clients

Size: ~180 employees from engineering, sales, client services, HR/finance, and a small internal IT/security team (2-3 people)

Work model: Fully remote-first. Employees distributed across multiple countries and time zones. No central office network, all access happens over the internet, from a mix of company-issued and personal laptops.

Infrastructure: 100% cloud-based. Uses AWS for hosting client applications, internal tools (project management, Git repositories), and storage. No on-premise servers.

Data handled:

- Source code and intellectual property for multiple client projects
- Client business data (varies by client — some fintech, some e-commerce, so compliance obligations differ per project)
- Employee personal data (HR, payroll)
- Credentials and secrets used to access client cloud environments



Rating

Function Name	Rating (Strong/Developing/Weak)	Justification	Gap	Recommendations
Govern	Developing	The absence of a central office system raises uncertainty about ownership / responsibility. While being online / remote is effective but fragmentation leads to difficulty in alignment on cybersecurity priorities. The governing body needs to formalize cybersecurity ownership structures and establish defined accountability mechanisms and make processes effective.	Communication gap, Leadership Clarity, Responsibility of risk, defining roles.	A formal Governance committee must be established that can govern all the areas A risk assessment every quarter should be made necessary
Identify	Weak	The BYOD Policy brings on a substantial risk of data identification and regulation of devices and information. A proper inventory system should be in place	BYOD Risk, Identification of resources, incomplete risk identification	an inventory system (like MDM) which tracks all devices should be made effective by the IT team Termination of BYOD Policy is necessary and in replacement company given authorized devices should be used by the approval of managers and be tracked by IT teams for weekly/monthly reports On the devices, admin level restrictions should be imposed by the IT team which are suggested by the Leadership

Protect	Developing	The organization's use of AWS services positively supports data storage, protection, and backup capabilities. However, effective management policies such as 'Principle of Least Privilege' should be taken into account	Authorization Management, a central system for tracking	A Quarterly Risk assessment by Auditors is necessary to find out gaps and hence improve them to support the maturity of the security posture Usage of the Principle of least privilege is important to ensure risk reduction
Detect	Weak	Absence of a SIEM and Physical Infrastructure makes threat Detection inherently more difficult Hypothetically, the presence of it could not detect the classic "Location-based" Anomaly due to the diversity of the teams Reliance on External networks could negatively impact the system due to difficulty in its troubleshooting	Network troubleshooting no SIEM, and the distributed team model requires behavior-based rather than location-based detection logic, which adds implementation complexity	A formal SIEM system should be installed over everything by the approval of the governing committee, made effective by the IT team Establishment of a Security operations center (SOC) for management of SIEM Establishing a mandatory VPN policy for all remote employees, governed by the leadership and managed by a dedicated network team
Respond	Developing	In case of an incident, the communication gap due to diversity and fragmentation could bring in resistance in Incident Response plan, which can lead to ineffective utilization of time and can result in significant Damage	Communication/coherence gap, quick response gap	The incident response team should have a formal Incident Response platform to make Incident response less troublesome and effective Incident Response Playbooks should be made by the Leadership to be

				followed by the IR team for timely responses and adding formal documentation to strengthen the security posture
Recover	Developing	With all data outsources to AWS, the backup and continuity should not be a problem, although data deleted on personal devices by mistake (because there is no admin restrictions in them) can be hard to recover. Especially if it's not backed up The organization's reliance on AWS provides adequate backup and recoverability for cloud-hosted data However, the data on personal devices can be at risk due to no admin restrictions on them, especially if it's not Backed up	BYOD, Data Regulation	Admin restrictions on company handed out devices should be made and any data on the BYOD devices should safely be moved onto the new devices with the guidance of the IT team to avoid privacy breaches for both the employee and the Company